



LIVECAMPUS

Remédiation et Législation

MINI CAS 3

ÉCOLE

Livecampus

PROFESSEUR

M. AUMAGY Yannick

GROUPE

G1

COURS

Remédiation et Législation

LIVRABLE

MINI CAS 3

CHAPITRES

7, 8 et 9

MEMBRES DU GROUPE



BADET Mael



LEBLOND Tristan



LOURENCO Quentin



MASIA Antoine

SOMMAIRE

ÉNONCÉ DU MINI-CAS	3
Contexte	3
RÉPONSES AUX TÂCHES	4
1. Analyser l'incident passé	4
2. Évaluer les impacts	10
3. Proposer des mesures d'amélioration	12
4. Concevoir un exercice de simulation de crise	14
5. Définir les rôles et responsabilités pendant la simulation	18
LIVRABLE ATTENDU	19
Contenu du livrable	19
GLOSSAIRE	20

ÉNONCÉ DU MINI-CAS

Contexte

À l'été **2026**, la **Direction générale des Finances publiques (DGFIP)**, dont dépend le site **impots.gouv.fr**, a été confrontée à une cyberattaque majeure par **accès illégitimes** à son système d'information.

Les faits connus sont les suivants :

- entre **juin et juillet 2026**, des attaquants ont obtenu des accès frauduleux en **usurpant des identifiants** d'agents (et/ou de tiers habilités), permettant la **consultation et l'extraction** de données ;
- le **12-13 août 2026**, un acteur malveillant a **revendiqué** le vol de données ; la DGFIP a alors confirmé l'ampleur de l'exfiltration ;
- environ **678 000** particuliers et professionnels sont concernés (dont **~350 000** particuliers et **~250 000** professionnels), avec notamment des **données fiscales** (revenu fiscal de référence, quotient familial, taux de prélèvement à la source, etc.) et des **données cadastrales** ;
- le site **impots.gouv.fr** et les **espaces usagers** (particuliers / professionnels) n'ont **pas** été compromis : les identifiants et mots de passe des contribuables n'ont pas été volés ;
- la **communication publique** a été critiquée : une partie du public a découvert l'affaire via la revendication / les médias avant une information officielle claire ; le gouvernement a ensuite présenté des **excuses**, saisi la **CNIL**, déposé plainte et réuni une **cellule de crise** ;
- la direction (administration / tutelle) souhaite à la fois **tirer les leçons** de cet incident et mettre en place un **exercice de simulation de crise** pour se préparer à de futurs scénarios.

Votre mission est de proposer une **analyse post-incident** et de concevoir un **plan de simulation de crise** adapté à ce contexte institutionnel.

Sources d'actualité (pour le contexte) : impots.gouv.fr · communiqué ministère

RÉPONSES AUX TÂCHES

1. Analyser l'incident passé

Reconstituez la chronologie de l'attaque et identifiez les points faibles dans la gestion technique et organisationnelle.

1.1. Reconstitution de la chronologie

Période	Événement	Analyse
Juin 2026	Début présumé des accès frauduleux au système d'information de la DGFIP.	Les attaquants utilisent des identifiants usurpés appartenant à des agents ou à des tiers habilités. Les connexions semblent donc provenir de comptes légitimes.
Juin à juillet 2026	Consultation et extraction progressive de données fiscales et cadastrales.	L'attaque reste active pendant plusieurs semaines. Les mécanismes de supervision n'identifient pas suffisamment tôt les connexions inhabituelles, les consultations massives ou les extractions anormales.
Fin juillet - début août 2026	Période probable d'analyse interne et de confirmation de l'incident.	La DGFIP doit rechercher l'origine des accès, déterminer les comptes compromis et évaluer le périmètre des données exfiltrées. Toutefois, aucune communication publique claire n'est encore réalisée.
12-13 août 2026	Un acteur malveillant revendique publiquement le vol des données.	La revendication rend l'incident public et accélère la confirmation de son ampleur par la DGFIP. Une partie des personnes concernées apprend donc l'existence de la fuite par les médias.
À partir du 13 août 2026	Confirmation d'une fuite concernant environ 678 000 personnes et professionnels .	Les données compromises comprennent notamment des informations fiscales et cadastrales. En revanche, le site impots.gouv.fr , les espaces usagers ainsi que les mots de passe des contribuables ne sont pas compromis.
Après la révélation publique	Activation des mesures institutionnelles et judiciaires.	Le gouvernement présente ses excuses, une cellule de crise est réunie, une plainte est déposée et la CNIL ^{1.1} est saisie. Les personnes concernées doivent également être informées des risques associés à la fuite.
Phase post-incident	Lancement d'un retour d'expérience et préparation d'un exercice de crise.	L'objectif est d'identifier les défaillances techniques et organisationnelles, puis d'améliorer la capacité de détection, de réaction et de communication de la DGFIP.

1.2. Points faibles dans la gestion technique

Compromission de comptes habilités

L'attaque a été rendue possible par l'utilisation frauduleuse d'identifiants appartenant à des agents ou à des tiers autorisés. Cela peut révéler plusieurs faiblesses :

- une authentification multifacteur^{1.2} absente, insuffisante ou contournable ;
- des mots de passe compromis par hameçonnage, vol de session ou réutilisation ;
- une gestion insuffisante des comptes de prestataires et des tiers ;
- des droits d'accès trop étendus par rapport aux missions réelles des utilisateurs ;
- l'absence de révision régulière des habilitations.

Même si les attaquants ont utilisé des comptes valides, leurs actions auraient dû être contrôlées selon le principe du **moindre privilège**.

Détection trop tardive

Les accès frauduleux se sont déroulés entre juin et juillet, alors que l'exfiltration n'a été publiquement confirmée qu'en août. Cette durée montre une détection insuffisamment rapide.

Les systèmes de surveillance auraient notamment dû détecter :

- une connexion depuis une adresse IP ou une zone géographique inhabituelle ;
- une connexion à des horaires anormaux ;
- une augmentation soudaine du nombre de dossiers consultés ;
- l'accès à des données sans rapport avec les fonctions du compte ;
- des téléchargements ou des extractions en volume important ;
- l'utilisation simultanée d'un même compte depuis plusieurs emplacements ;
- une succession inhabituelle de requêtes sur les bases fiscales ou cadastrales.

Cela peut indiquer un manque de centralisation des journaux, de règles de corrélation dans le SIEM^{1.3} ou de surveillance comportementale des utilisateurs et des entités, appelée **UEBA**^{1.4}.

Contrôle insuffisant de l'exfiltration

Les attaquants ont pu extraire des données sensibles sans être bloqués rapidement. Les mesures de prévention contre la fuite de données semblent donc insuffisantes.

Il aurait notamment fallu mettre en place :

- une limitation du nombre de dossiers consultables ou exportables ;
- des alertes en cas d'extraction massive ;
- une solution de prévention contre la fuite de données, ou **DLP**^{1.5} ;
- une traçabilité détaillée des consultations et téléchargements ;
- une validation supplémentaire pour les exports sensibles ;

- un cloisonnement plus strict des différentes catégories de données.

Segmentation et limitation des accès perfectibles

Un compte compromis ne devrait pas permettre d'accéder à un volume très important de données. L'incident peut donc révéler une segmentation insuffisante du système d'information ou des autorisations trop larges.

Une architecture fondée sur le modèle **Zero Trust**^{1.6} aurait permis de réévaluer chaque demande d'accès selon l'identité, le terminal utilisé, la localisation, le contexte de connexion et la sensibilité de la ressource demandée.

Gestion insuffisante des comptes de tiers

Le contexte indique que des identifiants de tiers habilités peuvent également avoir été usurpés. Or, les comptes externes présentent un risque particulier lorsqu'ils restent actifs trop longtemps ou disposent de privilèges excessifs.

La DGFIP devait donc s'assurer :

- que chaque compte externe était nominatif ;
- que les habilitations étaient limitées dans le temps ;
- que les droits étaient régulièrement réévalués ;
- que l'authentification multifacteur était obligatoire ;
- que les actions des tiers étaient surveillées et journalisées.

1.3. Points faibles dans la gestion organisationnelle

Déclenchement tardif de la cellule de crise

La cellule de crise semble avoir été réunie principalement après la médiatisation de l'incident. Elle aurait dû être activée dès que des indices suffisamment sérieux laissaient supposer une compromission et une possible fuite de données.

Une activation plus rapide aurait facilité :

- la coordination entre les équipes techniques, juridiques et dirigeantes ;
- la conservation des preuves ;
- l'évaluation du périmètre de l'incident ;
- le confinement des comptes compromis ;
- la préparation de la communication ;
- le respect des obligations réglementaires.

Coordination interne insuffisante

La gestion d'un incident concernant une administration comme la DGFIP nécessite une collaboration immédiate entre plusieurs acteurs :

- la direction ;
- les équipes de sécurité et d'exploitation ;
- le RSSI^{1.7} ;
- le délégué à la protection des données^{1.8} ;
- les services juridiques ;
- les services de communication ;
- la CNIL et les autorités judiciaires ;
- éventuellement l'ANSSI^{1.9} et les prestataires concernés.

Le délai de confirmation et les difficultés de communication peuvent révéler une chaîne de décision trop lente ou un partage insuffisant de l'information.

Communication publique tardive

L'un des principaux problèmes organisationnels concerne la communication. Une partie du public a appris l'existence de la fuite par la revendication de l'attaquant ou par les médias.

Cette situation entraîne plusieurs conséquences :

- une perte de confiance envers l'administration ;
- l'impression que l'incident a été dissimulé ;
- une augmentation du risque de désinformation ;
- l'absence de consignes immédiates pour les personnes concernées ;
- une maîtrise insuffisante du récit médiatique.

La communication aurait dû indiquer clairement les informations connues, les investigations encore en cours, les données concernées et non concernées ainsi que les précautions à prendre face aux risques de phishing^{1.10}.

Préparation de crise insuffisante

Les difficultés rencontrées peuvent également montrer que les procédures de gestion de crise n'étaient pas suffisamment préparées ou régulièrement testées.

La DGFIP aurait dû disposer :

- d'un plan de réponse aux incidents actualisé ;
- de critères précis d'activation de la cellule de crise ;
- d'une chaîne d'alerte connue de tous ;
- de modèles de notifications destinés aux victimes et aux autorités ;
- d'une liste claire des rôles et responsabilités ;
- d'exercices réguliers associant les équipes techniques, juridiques et communicantes.

Gestion réglementaire à renforcer

Les données fiscales et cadastrales sont des données à caractère personnel. L'incident constitue donc potentiellement une violation de données au sens du RGPD^{1.11}.

L'organisme doit notamment :

- documenter la violation ;
- évaluer les conséquences pour les personnes ;
- notifier la CNIL dans les meilleurs délais et, si possible, dans les **72 heures** après en avoir pris connaissance lorsqu'un risque existe ;
- informer rapidement les personnes concernées lorsque la violation est susceptible d'engendrer un risque élevé pour leurs droits et libertés.

La saisie de la CNIL est une mesure nécessaire, mais elle doit s'inscrire dans une procédure anticipée et non être uniquement déclenchée sous la pression médiatique.

1.4. Conclusion

L'attaque repose principalement sur l'usurpation de comptes pourtant autorisés. La faiblesse ne provient donc pas nécessairement d'une intrusion directe dans le site `impots.gouv.fr`, mais d'un contrôle insuffisant des identités, des habilitations et des comportements associés aux comptes internes ou partenaires.

La durée de l'exfiltration met également en évidence une capacité de détection trop faible. Sur le plan organisationnel, l'activation tardive de la cellule de crise et le retard de la communication ont aggravé les conséquences de l'incident en réduisant la confiance du public.

Les principales améliorations doivent ainsi porter sur l'authentification multifacteur, le moindre privilège, la surveillance comportementale, la prévention des extractions massives, le contrôle des tiers et la préparation régulière d'exercices de crise.

2. Évaluer les impacts

Mesurez les conséquences de l'incident : pertes financières, perte de confiance des clients, atteinte à l'image, non-conformité éventuelle vis-à-vis de la CNIL.

L'attaque contre la DGFIP a eu des conséquences importantes en raison du nombre de personnes concernées, de la sensibilité des données volées et de l'impact sur la confiance envers l'administration.

2.1. Impacts financiers

Le coût total de l'incident n'est pas encore précisément connu. Cependant, plusieurs dépenses sont à prendre en compte :

- investigation et analyse de l'attaque
- mobilisation des équipes informatiques et de cybersécurité
- sécurisation des comptes et renforcement des systèmes
- gestion de crise et communication avec les personnes concernées
- frais juridiques et procédures réglementaires
- temps de travail mobilisé au détriment des activités habituelles

Le coût financier peut donc être **élevé**, même sans perte d'argent directement subie par les contribuables.

2.2. Perte de confiance

La fuite concerne environ **678 000 particuliers et professionnels** et des informations sensibles telles que le revenu fiscal de référence, le quotient familial ou le taux de prélèvement à la source.

Cette situation peut provoquer :

- une perte de confiance envers la DGFIP et l'administration française en général.
- une inquiétude concernant la protection des données personnelles
- une augmentation des signalements de phishing et de tentatives de fraude
- une augmentation des demandes adressées aux services de l'administration

Le fait que certaines personnes aient appris l'incident par les médias ou par la revendication avant une communication officielle claire peut également accentuer cette perte de confiance.

2.3. Atteinte à l'image

L'attaque porte atteinte à l'image de la DGFIP et, plus largement, à celle de l'administration française. Une compromission de données fiscales peut donner l'impression que les systèmes de sécurité et les contrôles d'accès n'étaient pas suffisamment efficaces.

Cependant, un élément limite le risque immédiat : **les espaces personnels sur impots.gouv.fr n'ont pas été compromis et les mots de passe des contribuables n'ont pas été volés.**

2.4. Risques vis-à-vis de la CNIL et du RGPD

La fuite constitue une **violation de données personnelles**. La DGFIP doit donc respecter les obligations prévues par le RGPD, notamment concernant la documentation de l'incident et, lorsque les conditions sont réunies, sa notification à la **CNIL dans un délai de 72 heures après en avoir pris connaissance**.

Compte tenu du nombre de personnes touchées et de la sensibilité des données, le risque pour les personnes est important. La DGFIP doit également déterminer si les personnes concernées doivent être informées directement.

La CNIL pourra notamment examiner :

- les mesures de sécurité existantes avant l'attaque ;
- la gestion des habilitations et des identifiants ;
- la rapidité de détection et de réaction ;
- la qualité de la communication ;
- les mesures mises en place pour éviter une nouvelle attaque.

Bilan

Impact	Niveau
Coût financier	Élevé
Perte de confiance	Très élevé
Atteinte à l'image	Très élevé
Risque pour les personnes	Très élevé
Risque RGPD/CNIL	Élevé
Impact organisationnel	Élevé

En conclusion, l'impact le plus important est la perte de confiance des citoyens. La DGFIP doit donc renforcer la sécurité des accès, améliorer la détection des attaques et mettre en place une communication de crise plus rapide et transparente.

3. Proposer des mesures d'amélioration

Détaillez les mesures techniques, organisationnelles et de communication qui doivent être mises en œuvre pour renforcer la sécurité et la résilience.

Suite à l'incident, la DGFIP doit mettre en place des mesures permettant de **prévenir les accès frauduleux, détecter plus rapidement les attaques et améliorer la gestion de crise**.

3.1. Mesures techniques

- Mettre en place une **authentification multifacteur (MFA/ A2F)** pour les comptes des agents et des personnes habilitées.
- Renforcer la gestion des **identifiants et des droits d'accès** avec le principe du moindre privilège.
- Surveiller les connexions et détecter automatiquement les comportements inhabituels grâce à des outils de type **SIEM / EDR**^{3.1}.
- Réaliser régulièrement des **audits de sécurité, tests d'intrusion et scans de vulnérabilités**.
- Chiffrer les données sensibles, aussi bien lors de leur stockage que lors de leur transmission.
- Segmenter le réseau afin de limiter la propagation d'une attaque à l'ensemble du système d'information.
- Mettre en place des sauvegardes sécurisées, isolées et régulièrement testées.

3.2. Mesures organisationnelles

- Mettre à jour régulièrement les **habilitations** et supprimer immédiatement les accès inutiles ou les comptes inactifs.
- Former les agents aux risques liés au **phishing, à l'usurpation d'identité et au vol d'identifiants**.
- Mettre en place une procédure claire de **gestion et de remontée des incidents de sécurité**.
- Réaliser régulièrement des exercices de crise et des simulations de cyberattaques.
- Définir précisément les rôles du **RSSI, DSI, direction, DPO, juridique et communication** en cas d'incident.
- Effectuer régulièrement des audits et contrôles de conformité au **RGPD** et aux règles de sécurité internes.

3.3. Mesures de communication

La communication doit être **rapide, transparente et coordonnée** afin de préserver la confiance des usagers.

- Informer rapidement les personnes concernées lorsqu'une violation présente un risque important.
- Préparer à l'avance des **messages et procédures de communication de crise**.
- Désigner un porte-parole officiel afin d'éviter les informations contradictoires.
- Informer clairement les usagers sur les risques de **phishing et d'usurpation d'identité**.
- Communiquer régulièrement sur l'évolution de la situation et sur les mesures correctives mises en place.
- Coordonner la communication avec les autorités compétentes, notamment la **CNIL**.

3.4. Priorités

Priorité	Mesures principales
Immédiate	MFA / A2F, revue des habilitations, blocage des comptes suspects, surveillance renforcée
Court terme	Audits de sécurité, formation des agents, amélioration de la détection et procédures de crise
Moyen terme	Exercices de simulation, segmentation du SI, amélioration continue de la sécurité

En conclusion, la DGFIP doit agir sur trois niveaux complémentaires : renforcer techniquement le système d'information, améliorer l'organisation de la cybersécurité et rendre la communication de crise plus rapide et transparente. L'objectif est de passer d'une logique principalement réactive à une véritable démarche de **prévention, détection et résilience**.

4. Concevoir un exercice de simulation de crise

Élaborez un scénario réaliste pour tester la préparation de l'entreprise (par exemple, fuite de données bancaires ou nouvelle attaque DDoS). Définissez les acteurs impliqués, les objectifs et les étapes de la simulation.

Face aux enseignements de l'incident DGFIP de l'été 2026 (accès illégitimes, détection tardive de l'exfiltration, communication publique sous pression), nous proposons un **exercice de simulation de crise** en deux temps : d'abord un **table-top (TTX)**^{4.1} pour les décideurs, puis une **simulation complète** intégrant technique, direction, communication, juridique et métiers – conformément au chapitre 9 du cours.

Type d'exercice retenu

Niveau	Format (cours ch. 9)	Intérêt
1	Table-top exercise (TTX)	Valider les décisions, les délais de notification et les messages sans toucher au SI de production
2	Simulation complète de crise	Tester la cellule de crise « grandeur nature » (technique + communication + autorités)
Optionnel	Volet red team / blue team ^{4.2}	Simuler une usurpation de compte agent et la détection SOC ^{4.3} , en environnement dédié

Scénario réaliste : « Déclaration fiscale + revendication médiatique »

Le scénario se déroule un **lundi de mai**, en pleine période de **déclaration des revenus** (pic d'activité sur impots.gouv.fr).

Intrigue injectée aux participants :

- 08h30** – Le SOC détecte des connexions anormales depuis un compte d'**agent habilité** (horaires inhabituels, volumes de requêtes élevés sur des bases fiscales / RIB associés aux dossiers).
- 10h00** – Première confirmation technique : suspicion d'**usurpation d'identifiants** ; risque d'extraction de données (coordonnées, données fiscales, éventuellement **IBAN / coordonnées bancaires** liées aux dossiers).
- 12h30** – Un message circule sur les **réseaux sociaux** et un forum : un acteur malveillant revendique le vol de **données bancaires de contribuables** et menace de les publier. Les médias contactent déjà le service presse.
- 14h00** – Afflux inhabituel de connexions sur le portail public : début d'une **attaque DDoS**^{4.4} qui dégrade l'accès à impots.gouv.fr pour les usagers en train de déclarer.
- 16h00** – La CNIL et l'ANSSI doivent être informées ; les centres des Finances publiques reçoivent des appels de contribuables inquiets.

Ce scénario est volontairement **multi-vecteurs** (compte compromis + fuite revendiquée + DDoS + pression médiatique), car l'incident réel a montré que la crise n'est jamais « seulement technique ».

Objectifs de la simulation

1. **Mesurer les délais** de détection, de qualification et d'activation de la cellule de crise (indicateurs du ch. 7).
2. **Tester la communication de crise** : éviter que le public apprenne l'incident uniquement via les réseaux sociaux (point faible de l'été 2026).
3. **Vérifier la chaîne de conformité** : évaluation DPO / juridique, notification **CNIL**, coordination **ANSSI / CERT-FR**^{4.5}, plainte éventuelle.
4. **Valider le PCA**^{4.6} : continuité du service de déclaration malgré le DDoS (page de statut, canaux alternatifs, priorisation des services).
5. **Ancrer les rôles** : chaque acteur doit savoir quoi faire sans attendre une consigne orale unique.

Acteurs impliqués

Acteur	Rôle dans l'exercice
Direction / tutelle (DGFiP, cabinet)	Arbitrages stratégiques, validation des messages publics, relation avec le politique
RSSI / SSI	Pilotage technique de la réponse, lien SOC / IT
SOC / équipes IT & sécurité	Détection, confinement des comptes, anti-DDoS, conservation des preuves
DPO / juridique & conformité	Qualification « violation de données », délais CNIL, cadre légal
Communication / presse	Messages internes et externes, réseaux sociaux, FAQ usagers
Métiers (centres des Finances publiques, assistance usagers)	Continuité du service, script d'accueil téléphonique
Partenaires externes (ANSSI, CERT-FR, FAI ^{4.7} / anti-DDoS, prestataires)	Appui, filtrage, coordination nationale
Équipe d'animation (white cell)	Injecte les événements, joue médias / pirates / usagers, chronomètre les décisions

Étapes de la simulation

Phase 0 – Préparation (J–30 à J–7)

Rédaction du scénario et des injects, désignation des participants, règles de sécurité (pas d'action sur le SI de production), briefing « ce n'est qu'un exercice », critères de succès (délais, qualité des décisions, cohérence des messages).

Phase 1 – Table-top (½ journée)

Les décideurs déroulent le scénario autour d'une table : à chaque inject, ils annoncent leurs décisions (isoler le compte, communiquer ou non, notifier la CNIL, activer l'anti-DDoS). Objectif : aligner la doctrine avant le live.

Phase 2 – Simulation complète (1 journée)

Créneau	Inject	Attendu
T0	Alerte SOC compte agent	Qualification incident + ouverture ticket critique
T0+1h	Confirmation risque d'exfiltration	Activation cellule de crise + conservation preuves
T0+3h	Revendication réseaux sociaux	Message officiel validé ; porte-parole unique
T0+5h	Début DDoS portail	Activation protection / FAI ; page de statut usagers
T0+7h	Demande médias + appels centres	FAQ, consignes métiers, point presse encadré
T0+8h	Clôture de l'exercice	Décision de « fin d'exercice » et collecte des preuves de jeu

Phase 3 – Hot wash / retour d'expérience (J+1)

Débrief à chaud : retards, blocages, messages contradictoires, outils manquants. Production d'un compte rendu avec **plan d'actions** (procédures, MFA, détection des exfiltrations, kit de communication), conformément au chapitre 7 (amélioration continue).

Phase 4 – Capitalisation (J+15)

Mise à jour du plan de gestion de crise, indicateurs (temps de détection, temps avant premier communiqué, temps avant saisine CNIL), planification d'un nouvel exercice dans les 12 mois.

Critères de réussite (exemples)

- Cellule de crise activée en **moins de 60 minutes** après l'alerte critique.
- Premier **message officiel** publié **avant** que la rumeur ne domine les réseaux (objectif : ne pas reproduire le décalage de l'été 2026).
- Décision documentée sur la **notification CNIL** dans les délais légaux une fois la violation caractérisée.
- Portail usagers : stratégie anti-DDoS et communication de continuité opérationnelles.
- Aucune action destructive sur le SI réel ; toutes les preuves d'exercice tracées.

Sources :

- Cours Livecampus – *Remédiation et Législation*, **chapitre 9-A** (TTX, red/blue team, simulation complète, exercices inter-organisationnels)
- Cours Livecampus – *Remédiation et Législation*, **chapitre 7-B** (exercices de simulation, suivi d'indicateurs)
- Cours Livecampus – *Remédiation et Législation*, **chapitre 8-B** (communication de crise, PCA/PRA, leçons des cas réels)
- Contexte réel DGFIP 2026 – impots.gouv.fr

5. Définir les rôles et responsabilités pendant la simulation

Attribuez des responsabilités précises (direction, RSSI, IT, communication, juridique, métiers). Expliquez comment chaque rôle contribue à la gestion de crise.

Pour que l'exercice de simulation soit utile, chaque participant doit avoir un rôle bien défini, comme si c'était une vraie crise. Voici comment répartir les responsabilités, en lien avec le scénario choisi (par exemple une nouvelle attaque DDoS ou une fuite de données bancaires).

La direction

Pendant la simulation, la direction joue son propre rôle : elle doit prendre les décisions stratégiques en temps réel, comme décider si on ferme temporairement le site ou si on communique publiquement tout de suite. L'objectif est de tester sa capacité à décider vite sous pression, sans avoir toutes les informations en main dès le départ, comme ce fut le cas lors du vrai incident où la communication a manqué de clarté.

Le RSSI

Il pilote la partie technique de la simulation : il doit analyser le scénario fictif (par exemple une alerte de fuite de données bancaires), évaluer sa gravité et proposer des mesures de confinement. L'exercice permet de vérifier s'il réagit assez vite et si ses décisions techniques sont pertinentes face à un scénario qu'il ne connaît pas à l'avance.

L'équipe IT

Elle doit appliquer concrètement les mesures demandées par le RSSI : isoler des serveurs fictifs, simuler le blocage d'une attaque DDoS, ou vérifier l'ampleur d'une fuite de données. Le but est de tester si les procédures techniques sont claires et si l'équipe IT [5.1](#) sait les exécuter rapidement, sans hésitation, contrairement à un incident réel où la panique peut ralentir les réactions.

Le service communication

C'est un rôle central dans cette simulation, vu que la communication a posé problème lors du vrai incident (des clients ont appris la nouvelle par les réseaux sociaux avant l'entreprise). Pendant l'exercice, ce service doit préparer un communiqué de crise fictif, s'entraîner à répondre à de fausses questions de journalistes ou de clients, et vérifier que l'info officielle sort avant que les rumeurs ne se propagent.

Le service juridique

Il doit s'entraîner à évaluer les obligations légales liées au scénario, par exemple si des données bancaires fictives sont concernées, quand et comment notifier la CNIL. L'exercice permet de vérifier que les délais légaux sont bien connus et respectés, et que l'entreprise sait quoi dire sans s'exposer à des risques juridiques.

Les métiers impactés

Ce sont les équipes qui font tourner l'activité au quotidien, ici par exemple le service client ou les ventes en ligne. Pendant la simulation, elles doivent s'entraîner à gérer l'impact concret sur leur travail, comme faire face à des clients inquiets ou trouver une solution alternative si le site de vente est simulé comme étant hors service.

Résumé : Chaque rôle est testé dans sa capacité à réagir vite et de façon coordonnée. L'intérêt de la simulation, c'est justement de reproduire les failles observées lors du vrai incident (notamment la communication confuse) pour vérifier que l'équipe a progressé et sait mieux gérer une crise similaire à l'avenir.

LIVRABLE ATTENDU

Un document PDF d'aspect professionnel comprenant :

- une **page de garde** (nom de l'école, nom du cours, nom du professeur, noms des membres du groupe) ;
- une **page reprenant l'énoncé** du mini-cas ;
- des **pages numérotées** avec une présentation claire et professionnelle ;
- des **graphiques, schémas ou images** pour illustrer les analyses et rendre la lecture plus agréable.

Contenu du livrable

- Une **page de synthèse** : récapitulatif de l'incident passé et plan global d'amélioration.
 - Le **détail des calculs** : chronologie de l'incident + impacts mesurés (financiers, réputationnels, organisationnels) + description du scénario de simulation.
 - Vos **recommandations priorisées** : liste des mesures correctives à mettre en œuvre immédiatement et étapes de la simulation à organiser en priorité.
-

GLOSSAIRE

Les chiffres en exposant dans le texte (ex. **1.1**, **3.1**, **4.2**) renvoient aux définitions ci-dessous. La première partie du numéro indique la question où le terme apparaît pour la première fois.

- 1.1 CNIL** – Commission nationale de l'informatique et des libertés. Autorité de contrôle du RGPD en France ; doit être notifiée en cas de violation de données personnelles (art. 33). [↩](#)
- 1.2 MFA / A2F** (*Multi-Factor Authentication* / authentification à deux facteurs) – Méthode d'authentification exigeant au moins deux preuves d'identité distinctes (mot de passe + code, application, clé matérielle, etc.). [↩](#)
- 1.3 SIEM** (*Security Information and Event Management*) – Plateforme qui centralise les journaux (logs) et détecte des corrélations / anomalies pour alerter le SOC. [↩](#)
- 1.4 UEBA** (*User and Entity Behavior Analytics*) – Analyse comportementale des utilisateurs et entités pour détecter des activités anormales (connexions inhabituelles, extractions massives, etc.). [↩](#)
- 1.5 DLP** (*Data Loss Prevention*) – Ensemble de contrôles visant à empêcher la fuite ou l'exfiltration non autorisée de données sensibles. [↩](#)
- 1.6 Zero Trust** – Modèle de sécurité où aucune connexion n'est considérée comme fiable par défaut : chaque accès est vérifié selon l'identité, le contexte et la ressource demandée. [↩](#)
- 1.7 RSSI** (*Responsable de la Sécurité des Systèmes d'Information*) – Cadre chargé de piloter la politique de cybersécurité de l'organisation et de coordonner la réponse aux incidents. [↩](#)
- 1.8 DPO** (*Data Protection Officer* / Délégué à la protection des données) – Responsable du respect du RGPD ; intervient notamment pour évaluer et notifier une violation de données à la CNIL. [↩](#)
- 1.9 ANSSI** – Agence nationale de la sécurité des systèmes d'information. Autorité nationale française en cybersécurité ; accompagne et oriente en cas d'incident majeur. [↩](#)
- 1.10 Phishing** – Technique d'ingénierie sociale qui vise à tromper une victime (e-mail, SMS, site faux) pour lui soutirer des identifiants ou déployer un malware. [↩](#)
- 1.11 RGPD** – Règlement général sur la protection des données (UE). Impose notamment la notification à l'autorité (CNIL) sous **72 h** en cas de violation présentant un risque pour les personnes. [↩](#)
- 3.1 EDR** (*Endpoint Detection and Response*) – Solution de détection et de réponse sur les postes et serveurs (endpoints), complémentaire au SIEM pour identifier comportements malveillants locaux. [↩](#)
- 4.1 TTX** (*Table-Top Exercise*) – Exercice sur table : les décideurs déroulent un scénario fictif et décident des actions sans intervenir sur le SI de production. [↩](#)
- 4.2 Red team / Blue team** – Exercice technique où une équipe offensive (red) simule l'attaquant et une équipe défensive (blue) protège et détecte. [↩](#)
- 4.3 SOC** (*Security Operations Center*) – Centre opérationnel de sécurité qui surveille en continu les alertes, analyse les incidents et coordonne la réponse technique. [↩](#)
- 4.4 DDoS** (*Distributed Denial of Service*) – Attaque par déni de service distribué : un grand volume de requêtes provenant de nombreuses sources sature un service (site, serveur) pour le rendre inaccessible. [↩](#)
- 4.5 CERT-FR** – Centre gouvernemental français de veille, d'alerte et de réponse aux attaques informatiques (rattaché à l'ANSI). Il publie des fiches réflexes et peut accompagner les incidents majeurs. [↩](#)
- 4.6 PCA** (*Plan de Continuité d'Activité*) – Dispositif visant à maintenir les activités essentielles pendant et après un sinistre ou un incident majeur (souvent associé au PRA, plan de reprise). [↩](#)
- 4.7 FAI** (*Fournisseur d'Accès à Internet*) – Opérateur qui fournit la connectivité Internet (et souvent le filtrage anti-DDoS en amont). [↩](#)
- 5.1 IT** (*Information Technology*) – Systèmes d'information « classiques » (serveurs, postes, applications métier, web) et équipes techniques qui les exploitent. [↩](#)